Lesson notes · for you

The OWASP Top 10 for LLM applications

AI security · University · Lesson 2

Time	Materials
20 min	The ten risks (on the slides); An LLM app you are building, or a design on paper; A phone or computer for the escaping test, if you have one

Learning goals

- Name the ten OWASP risks for LLM apps, with an example of each.
- Treat model output as untrusted: escape it before it is used.
- Keep secrets and access rules out of prompts.

Activity: Ten-risk review

1. Sort (5 min): Write the ten risks on cards (number and name). With a partner, sort them into what goes in, what comes out and the system around the model, then check against the slide.
2. Review (8 min): For an app you are building, or a made-up design, write one line per risk: could it happen here, and what is the evidence?
3. Fix (5 min): Pick your three biggest risks and write a control for each that changes the design (escape output, remove a tool, add a limit), not just the prompt.
4. Test (2 min): For one control, write the test that would prove it works, such as escaping five tricky replies.

Review your own app or a made-up design. Never test a live app without written permission.

Discussion

- Why is the model's reply untrusted, even though your app asked for it?
- Which risk is easiest to fix by design?
- Why doesn't “never reveal this” protect a secret?

Check yourself

- Write one risk from the ten that applies to an app you use, and its control.

Try it this week

Take an LLM app you use or are building and go down the ten risks: one line each, could it happen here and what stops it. Then fix the three you can fix fastest.

Worksheet

The OWASP Top 10 for LLM applications

AI security · University · Lesson 2

Name _____ Class _____ Date _____

1 **A study assistant can delete files, but its job is only to read them. Which risk is that?**

◯ Excessive agency ◯ Unbounded consumption ◯ Misinformation

2 **Match each OWASP risk to an example of it.**

LLM01 Prompt injection	• • • •	One user's endless requests run up a huge bill
LLM02 Sensitive information disclosure	• • • •	It can delete files when it only needs to read them
LLM06 Excessive agency	• • • •	It quotes another student's essay
LLM10 Unbounded consumption	• • • •	A web page it summarises tells it to ignore its rules

3 **The course page shows the chatbot's replies. Finish escape_html(t) so the characters & < > " become & < > ". Mind the order: the starter forgets the ampersand.**

```
def escape_html(t):
    t = t.replace("<", "&lt;")
    t = t.replace(">", "&gt;")
    return t

reply = 'Mark: <b>9</b> & "well done"'
print(escape_html(reply))
```

Write your program:

4 **What does this print?**

```
def bad(t):
    t = t.replace("<", "&lt;")
    return t.replace("&", "&amp;")

print(bad("<b>"))
```

◯ <b> ◯ <b> ◯ <b>

5 **Which of these keep a secret safe from system prompt leakage? Choose all that apply.**

☐ Keep API keys in the app's code or vault, never in the prompt

☐ Decide who may see what in code, not in the prompt ☐ Tell the model “never reveal this”

☐ Give the model only this user's data ☐ Write the secret in another language

✎ **Pick an LLM app you use. Which of the ten risks worries you most for it, and what would you check first?**